DRIMO

Auditoría Técnica y Propuesta de Implementación

Opina+

React · TypeScript · Supabase · Equipo técnico Drimo · Abril 2026

01 Lo que encontramos

02 Cómo lo resolvemos

PARTE 01

Lo que encontramos

Auditoría técnica del proyecto Opina+

Resumen Ejecutivo

DRIMO

Estado general del proyecto al 8 de abril de 2026

Base sólida con arquitectura bien pensada — no apta para producción crítica sin resolver primero las vulnerabilidades de seguridad.

✓ Puntos fuertes

- Estructura feature-based bien organizada
- Patrón outbox offline-first sofisticado — queue persistida, backoff exponencial
- Acceso a datos protegido mayormente por RLS + RPCs en Postgres
- Lazy loading de 30+ rutas con code splitting en Vite

✗ Puntos críticos

CRÍTICO

Restricción de votación 100% bypasseable desde el navegador

CRÍTICO

Credenciales de acceso admin guardadas en texto plano

ALTA

84 puntos donde se desactivan las verificaciones automáticas de errores

ALTA

Errores en rutas críticas que desaparecen sin dejar rastro

Vulnerabilidades Críticas

DRIMO

Deben cerrarse antes de cualquier lanzamiento

CRÍTICO

#1 — Restricción de votación solo en el navegador

El límite de cuántas veces puede votar un usuario existe solo en el navegador y puede eliminarse fácilmente desde las herramientas del desarrollador. Cualquier usuario técnico puede votar sin restricciones.

```
signalStore.ts:95-135
```

Cómo se resuelve →

Mover la regla al servidor. El servidor valida y hace cumplir el límite — el navegador solo muestra el estado para una buena experiencia.

CRÍTICO

#2 — Credenciales de acceso admin guardadas en texto plano

Las credenciales de acceso se guardan en el navegador en texto plano. Si alguien logra inyectar código malicioso en el sitio, puede robarlas fácilmente.

```
accessGate.ts:26  ·  AccessGate.tsx:139
```

Cómo se resuelve →

El servidor emite un permiso seguro que el navegador solo puede leer, no modificar ni robar directamente. Se elimina toda lógica de almacenamiento local.

Seguridad — Hallazgos Adicionales

DRIMO

8 issues de severidad alta y media

N°	Severidad	Hallazgo	Descripción
#3	ALTA	**Dirección del sistema en el código**	Una dirección interna queda expuesta en el código que se envía a producción.
#4	ALTA	**Datos de invitación sin limpiar**	Si el proceso falla a mitad, los datos del usuario quedan guardados y pueden reutilizarse.
#5	MEDIA	**Protección de sesiones desactivada**	Se desactivó un mecanismo que evita conflictos cuando el mismo usuario tiene varias sesiones abiertas.
#6	MEDIA	**Errores invisibles en producción**	Cuando algo falla, el error desaparece sin dejar rastro ni alertar al equipo.
#7	MEDIA	**Límite de acciones bypasseable**	El límite de acciones por usuario existe solo en el navegador, igual que la votación.
#8	MEDIA	**Sin registro de acciones admin**	No queda rastro de qué hicieron los administradores — quién cambió qué y cuándo.
#9	MEDIA	**Identificación de dispositivo débil**	El identificador del dispositivo se resetea al limpiar caché — el mismo usuario puede pasar como otro.
#10	BAJA	**Datos sensibles en registros de prueba**	El sistema de logging puede incluir información personal de los usuarios en modo desarrollo.

TypeScript & Arquitectura

DRIMO

Deuda técnica que debilita las protecciones del sistema

Calidad de código

ALTA

Las partes más críticas del sistema se comunican con la base de datos desactivando las verificaciones automáticas de errores.

ALTA

Las reglas de calidad de código que detectan errores comunes están desactivadas deliberadamente — hay un comentario en el código que lo reconoce.

ALTA

84 puntos en el código donde se desactivan las verificaciones automáticas. El sistema de control de calidad no los bloquea.

MEDIA

Una función de cálculo tiene el tipo de dato incorrecto — los errores de datos en ese flujo no serán detectados automáticamente.

BAJA

La configuración silencia errores de compatibilidad de librerías externas.

Arquitectura

✓ Fortalezas

- Estructura bien organizada por funcionalidad
- Sistema offline-first sofisticado con reintentos automáticos
- Lógica de negocio en el servidor — reduce inconsistencias
- Carga de pantallas diferida para mejor rendimiento

✗ Problemas estructurales

- 36+ puntos del código se conectan directamente a la base de datos — sin capa unificada
- La restricción de votación no tiene validación en el servidor (hay un pendiente en el código)
- Si una pantalla falla al cargar, el usuario ve un spinner eterno sin opción de reintentar
- Los mismos datos se piden múltiples veces sin reutilizar lo ya cargado

Performance

DRIMO

Ineficiencias que afectan la experiencia del usuario

ALTO

Los datos se piden de nuevo en cada pantalla

Cada vez que el usuario navega, la app vuelve a pedir todo desde cero aunque ya lo haya cargado. Hace la experiencia más lenta y consume más recursos.

MEDIO

Consultas que esperan innecesariamente

Algunas pantallas hacen varias consultas una detrás de otra cuando podrían hacerse al mismo tiempo, aumentando el tiempo de carga.

MEDIO

Pantallas que no cargan sin aviso

Si una pantalla falla al cargar por un problema de conexión, el usuario ve un indicador de carga girando indefinidamente sin poder reintentar.

MEDIO

Sin precarga de pantallas críticas

Las pantallas principales no se precargan, lo que genera una espera visible al navegar por primera vez.

MEDIO

Verificación de permisos sin optimización

La verificación de permisos se ejecuta en cada consulta a la base de datos sin guardar el resultado, generando trabajo extra en cada acción.

BAJO

Errores de analytics que pasan desapercibidos

Los registros de analytics fallan silenciosamente, si algo sale mal, nadie se entera.

PARTE 02

Cómo lo resolvemos

Propuesta de implementación · 489 UF · 9 semanas

Respuestas a sus preguntas

DRIMO

Antes de avanzar, alineamos el alcance

¿Incluye la solución de las vulnerabilidades críticas?

Sí. Las 2 vulnerabilidades críticas se solucionan y cierran dentro de este proceso — no solo se documentan.

¿Qué queda resuelto al término de las 9 semanas?

El producto estará listo para operar con usuarios reales: seguro, estable, con monitoreo activo y con experiencia verificada en móvil.

¿Incluye priorización de qué se resuelve primero?

Sí. Las áreas están ordenadas por urgencia e impacto: primero lo que bloquea el lanzamiento, luego estabilidad y calidad, y finalmente la base técnica de largo plazo.

¿Tienen estimación del costo para llegar a producción?

489 UF con puesta en producción incluida. Al finalizar, Opina+ está en producción y operativo.

Áreas de Trabajo

DRIMO

4 ejes ordenados por impacto y urgencia

ÁREA 1
Correcciones inmediatas

- Configuración de entorno
- Captura global de errores
- Fix pantallas de Login y Register
- Seguridad en el flujo de invitación
- Pantallas que no cargan correctamente
- Activar reglas de calidad de código

ÁREA 2
Seguridad crítica

- Restricción de votación en el servidor
- Control de acceso seguro
- Contratos de comunicación con la base de datos
- Votos duplicados al usar múltiples pestañas
- Registro de acciones de administración
- Protección de sesiones simultáneas

ÁREA 3
Calidad & rendimiento

- Sistema de caché de datos
- Optimización de consultas a la base de datos
- Monitoreo de errores en producción
- Medición de velocidad de carga
- Revisión de experiencia en celular
- Completar sección de tendencias en vivo

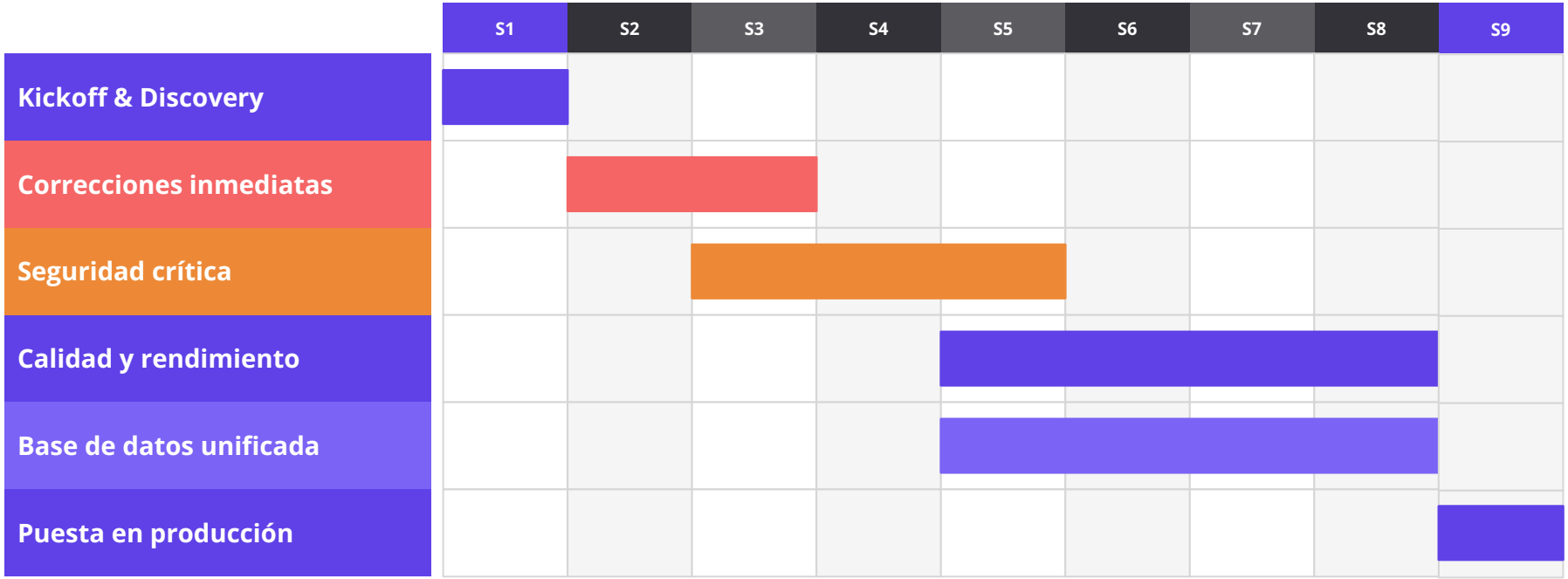
ÁREA 4
Base de datos unificada

- Capa de acceso a datos unificada

Plan de Trabajo

DRIMO

9 semanas · S1 kickoff · S2–S8 implementación · S9 despliegue



** Semanas estimadas. Se ajustan al inicio según disponibilidad y prioridades del equipo.*

Inversión

Precio fijo · Incluye puesta en producción

489 UF

+ IVA

9 semanas · Precio fijo

- Cierre de las 2 vulnerabilidades críticas
- Sistema de monitoreo de errores activo
- Experiencia verificada en dispositivos móviles
- Capa de datos unificada y documentada
- Backlog ejecutable por cualquier equipo
- Puesta en producción incluida

Para el éxito del proyecto

1 Contraparte técnica

Se requiere un desarrollador disponible para responder consultas dentro de 24 horas hábiles.

2 Acceso al repositorio

Acceso completo al código fuente, configuración y entorno de staging para poder trabajar.

3 Disponibilidad de agenda

Al menos reunión de kickoff y reunión de entrega. Las adicionales se coordinan con anticipación.

4 Decisiones ágiles

Algunas definiciones requieren validación de Juan Ignacio — se espera respuesta en el mismo día.

DRIMO

¿Cómo avanzamos?

El diagnóstico está hecho. El plan está definido.
El siguiente paso es dar el visto bueno para iniciar.

- 2 vulnerabilidades críticas que bloquean el lanzamiento
- Base técnica sólida que requiere refuerzo antes de producción
- Arquitectura bien pensada — buena fundación para crecer
- 489 UF · 9 semanas · producto en producción al finalizar

matias.carriles@drimo.com · www.drimo.com